TRACK 2: THE AGENT THAT CAN EXPLAIN WHY

Breach72

Agents that investigate a personal data breach across separate systems and tell the data protection officer, within the 72-hour GDPR window, whether to notify, and why.

Team Archaios: Marek Porycki, psychologist and GDPR compliance practitioner, Broker Business sp. z o.o. (brokerbusiness.eu)

PROBLEM AND USER

72 hours, four systems, one decision

- **User:** data protection officer in an SME or a municipality
- GDPR Art. 33: notify the authority within 72 hours of awareness
- Art. 34: tell the people when the risk is high

The facts sit in different places:

- incident system and access logs
- record of processing activities
- asset and encryption register
- processor contracts

SOLUTION AND OUTPUT

A decision the DPO can defend

- **Decision:** document only, notify the authority, also notify people, or escalate to the DPO
- **Why:** every sentence cites a finding id, its source rows and the legal article
- **Draft notification** with the Art. 33(3) fields; gaps are marked, never guessed
- **Open questions**, the **72-hour clock** and a full JSONL **trace**

Decision support, not legal advice. All data is synthetic.

AGENT WORKFLOW

Five agents, real loops



- Claim without evidence: **veto**, back to the Planner (max 3 iterations)
- Key facts re-checked with a **different template**; disagreement opens a **conflict** branch
- Borderline score, conflict or assumed awareness time: **escalate to a human**

STACK AND SPONSOR TECHNOLOGY

Who does what

Zetaris

One governed SQL access point to the four source systems. Vetted templates only. Responses recorded for replay (sample mode).

Meterless

World Model for case state and evidence; H-MEM for verified organisational facts, always re-verified at the source.

NVIDIA Nemotron

Smaller model plans, larger model assesses evidence and explains. It never makes the decision. Model name logged per call.

Built in **Cursor** with project rules (.cursor/rules). Python standard library runtime.

WHAT IS UNIQUE

The model explains. The rule decides.

- ENISA 2013 severity **SE = DPC x EI + CB**, mapped to GDPR Art. 33 and 34
- Tested against **11 worked cases of EDPB Guidelines 01/2021** (29 tests passing)
- Auditor agent with a **veto** and **independent re-verification** of the number of people, encryption, disclosure and data categories
- Model output is accepted only if every finding id it cites exists

RESULT AND TRACE

Real runs, real branches (local dev backend, synthetic data)

```
Case 2: 1 200 records (name, PESEL, address, benefit) e-mailed to an unknown address
Decision: notify_authority_and_individuals   SE 3.5 (high)   deadline 2026-10-23T09:15
F01 [verified] Moment the controller became aware of the breach
F02 [verified] Data categories in PR-07: address, benefit_type, name, pesel  (re-verified:
T08_EXPORT_CATEGORIES)
F03 [verified] 1200 records left the system in the logged event(s)  (re-verified: T04_EXPORT_ITEMS_COUNT)
F04 [verified] Data sent outside the controller: email_send to unknown.recipient@exam  (re-verified:
T02_INCIDENT_UPDATES)
F05 [verified] The e-mailed file was NOT encrypted  (re-verified: T06_ASSET_SECURITY)

Same case, next day: recipient confirmed deletion in writing
Decision: notify_authority   SE 2.5 (medium)

Case 3: ransomware on HR server; log shows 2 GB outbound, IT report says no exfiltration
Decision: escalate_to_dpo   flags: special_categories_art9, phased_notification
```

STATUS, LIMITATIONS, NEXT

Where we are (22 October 2026)

- Done: 5 agents, rule set, 5 test cases, trace, report
- Done: Zetaris adapter with timeout, retries, recording and replay
- In progress: live Zetaris sources, Meterless World Model and H-MEM, Nemotron calls

Limitations

- Decision support, not legal advice
- Synthetic data only
- ENISA method; national authority practice may differ

github.com/BrokerBusiness-ai/breach72 (Apache-2.0)